

RELATÓRIO DE INCIDENT RESPONSE (BLUE TEAM)

Controlo do Documento

Organização: IEFEP Faro - Laboratório CET Cibersegurança

Autor do relatório / Analista SOC: Andrey Dudkin - Técnico Especialista em Cibersegurança (formando)

Data do relatório: 17 de julho de 2026

1. Identificação do Incidente

Data: 17 de julho de 2026

Hora de deteção: 10:22:24 UTC (primeira falha de autenticação registada)

Sistema(s) afetado(s): srv-ubuntu-blueteam (100.84.78.52) - serviços FTP (21) e SSH (22)

Tipo de ataque: Acesso não autenticado via FTP anónimo + Brute force / Credential Access via SSH

Severidade: Alta

Detetado por: auth.log / Wazuh (regra 5760) + Canary Watcher (script Python próprio de deteção de acesso a ficheiro isca)

Estado atual: Contido - IP atacante bloqueado via UFW, credencial comprometida alterada, serviços reconfigurados

2. Resumo Executivo

No dia 17 de julho, o servidor do laboratório foi alvo de um ataque que combinou acesso anónimo ao serviço FTP com escrita, e um ataque de força bruta contra o SSH, que obteve a password do utilizador admin em cerca de 3 minutos e meio. O atacante acedeu ao sistema e exfiltrou dois ficheiros com credenciais, incluindo o ficheiro isca colocado propositadamente pela nossa equipa. O ataque foi detetado em tempo real através dos logs de autenticação e do nosso mecanismo de deteção próprio (Canary Watcher), que alertou via e-mail, assim que o ficheiro isca foi acedido. O atacante foi identificado e bloqueado, e as vulnerabilidades exploradas foram corrigidas de imediato.

3. Detalhes do Incidente

Vetor de ataque (como entrou): Duplo vetor:

FTP anónimo com escrita ativa (vsftpd 3.0.5), usado para confirmar exposição e depositar ficheiro;

Brute force SSH (Hydra) contra o utilizador admin, com password fraca

IP atacante: 100.114.252.67

País / ASN (se identificado): Não determinado - rede interna do laboratório (Tailscale/VPN, tailnet tail74269e.ts.net)

Ferramenta suspeita: Hydra (padrão de ~245 tentativas em 3m40s, intervalo curto e constante) para SSH; cliente FTP standard para acesso anónimo

Conta(s) / utilizador(es) envolvidos: admin (credencial comprometida: password fraca "-password-"); acesso anônimo FTP (sem conta associada)

4. Evidências

4.1 Log de autenticação SSH

```
$ grep "Failed password" /var/log/auth.log | tail -20
10:22:24 srv-ubuntu sshd[#####]: Failed password for admin from 100.114.252.67 port
##### ssh2
... (sequência de ~10 falhas em 10:22-10:29) ...
10:25:xx srv-ubuntu sshd[#####]: Accepted password for admin from 100.114.252.67 port
##### ssh2

# Alerta Wazuh
Rule: 5760 -> 'sshd: Multiple authentication failures.'
srcip: 100.114.252.67 | user: admin
```

Explicação da evidência:

O auth.log mostra uma sequência de falhas de autenticação seguidas de um login bem-sucedido para o mesmo utilizador (admin) a partir do mesmo IP - padrão característico de brute force com sucesso final. A regra Wazuh 5760 agrega estas falhas e dispara o alerta automaticamente.

4.2 Log do Canary Watcher

```
$ cat /tmp/alert.log
[10:29:29] CANARY TRIGGERED — Ação=ABERTURA, ficheiro=/tmp/passwords.txt,
IP=100.114.252.67, user=admin
[10:32:52] CANARY TRIGGERED — Ação=LEITURA, ficheiro=/tmp/passwords.txt,
IP=100.114.252.67
[10:34:49] CANARY TRIGGERED — Ação=LEITURA, ficheiro=/tmp/passwords.txt,
IP=100.114.252.67
-> E-mail de alerta enviado via SMTP (Gmail App Password) para a conta do analista
```

Explicação da evidência:

O script de monitorização próprio (~/.bluewatch/.sys_monitor.py, baseado em watchdog) detetou três acessos ao ficheiro isca /tmp/passwords.txt em menos de 6 minutos, confirmando que o atacante localizou e leu repetidamente o ficheiro sensível após obter acesso SSH. Cada acesso gerou um alerta por email com IP de origem da sessão.

4.3 Confirmação de sessão ativa

```
$ who
admin pts/0 2026-07-17 10:25 (100.114.252.67)
```

Explicação da evidência:

O comando who confirma que a conta admin tinha uma sessão SSH ativa a partir do IP 100.114.252.67 no momento da análise, validando que o brute force teve sucesso e o atacante estava efetivamente dentro do sistema.

5. Timeline

Hora (UTC)	Evento	Evidência	Fonte / Ferramenta
10:22:24	Início de tentativas de login SSH falhadas	"Failed password for admin from 100.114.252.67"	auth.log / Wazuh
10:22 – 10:29	Sequência de falhas de autenticação (padrão brute force)	~10 tentativas registadas em sequência rápida	auth.log
10:25	Login SSH bem-sucedido do utilizador admin	Sessão ativa confirmada via who, origem 100.114.252.67	Analista / who
10:29:29	CANARY TRIGGERED - primeira abertura do ficheiro isca	/tmp/passwords.txt, ação=ABERTURA	Canary Watcher (alert.log)
10:32:52 / 10:34:49	Novos acessos ao ficheiro isca (leituras repetidas)	2 novos eventos no alert.log	Canary Watcher
10:35	IP de origem bloqueado via UFW	sudo ufw deny from 100.84.78.52 to any	Analista / UFW

6. Indicadores de Compromisso (IOCs)

Tipo	Valor	Observações
IP	100.114.252.67	Origem da sessão SSH com credencial comprometida (admin)
Utilizador	admin	Conta com password fraca, comprometida por brute force
Ficheiro	/tmp/passwords.txt	Ficheiro isca acedido e exfiltrado pelo atacante
Ficheiro	/tmp/zzz.txt	Ficheiro sensível exfiltrado
Ficheiro	pawned_by_redteam.txt	Ficheiro depositado pelo atacante via FTP anónimo em /srv/ftp/upload
Padrão	~245 tentativas / 3m40s SSH	Consistente com brute force automatizado (Hydra)

7. Impacto

Acesso conseguido?: Sim - acesso SSH interativo com a conta admin, e acesso de leitura/escrita via FTP anónimo

Dados afetados?: Sim - /tmp/passwords.txt e /tmp/zzz.txt exfiltrados (credenciais/hashes); ficheiro externo pawned_by_redteam.txt introduzido no sistema

Sistema comprometido?: Parcialmente - acesso ao nível da conta admin confirmado; sem evidência de escalada a root nem de persistência instalada

Tempo de indisponibilidade (downtime): Nenhum - os serviços mantiveram-se disponíveis durante todo o incidente

Explicação:

Apesar de não ter havido interrupção de serviço, o impacto ao nível de confidencialidade foi significativo: o atacante confirmou a exposição do FTP, obteve uma credencial SSH válida e exfiltrou dois ficheiros com dados de credenciais - um deles zzz.txt com dados sensíveis. O curto intervalo entre o login SSH (10:25) e o primeiro acesso ao ficheiro isca (10:29:29) indica reconhecimento rápido e direcionado por parte do atacante.

8. Ações Tomadas (Blue Team)

- Bloqueio imediato do IP do atacante via UFW (sudo ufw deny from 100.84.78.52 to any).
- Confirmação manual das tentativas de brute force em /var/log/auth.log (grep "Failed password").
- Verificação de sessões ativas (who) para confirmar extensão do acesso obtido.
- Abertura de caso formal com documentação da timeline e evidências para referência futura.
- Reativação do Fail2ban para o jail sshd (estava desativado propositadamente para permitir o exercício).
- Desativação do acesso anónimo e da escrita no vsftpd (anonymous_enable=NO, write_enable=NO, anon_upload_enable=NO).
- Alteração imediata da password do utilizador admin comprometido.

9. Root Cause

O incidente foi possível devido a duas fraquezas de configuração simultâneas:

O serviço FTP permitia login anónimo com permissão de escrita, expondo o sistema de ficheiros a qualquer atacante sem autenticação;

O serviço SSH aceitava autenticação por password, com uma credencial fraca ("-password-") atribuída à conta admin, sem rate-limiting eficaz - o Fail2ban estava propositadamente desativado nesta fase do exercício, eliminando a única camada de proteção reativa contra brute force. A combinação destes dois vetores, mais a existência de um ficheiro sensível (zzz.txt), ampliou a superfície de exposição real do sistema.

10. Mapeamento MITRE ATT&CK

- T1595 – Active Scanning (reconhecimento nmap detetado indiretamente pelo padrão de tráfego)
- T1190 – Exploit Public-Facing Application (exploração do FTP anónimo com escrita)
- T1110.001 – Brute Force: Password Guessing (ataque Hydra contra SSH)
- T1078 – Valid Accounts (uso da credencial admin comprometida)
- T1005 – Data from Local System (localização de passwords.txt e zzz.txt)
- T1041 – Exfiltration Over C2 Channel (exfiltração via SCP sobre a sessão SSH legítima)

11. Recomendações

- Desativar definitivamente a autenticação por password no SSH, migrando para chave pública exclusiva (PasswordAuthentication no).
- Manter o Fail2ban sempre ativo em produção, com maxretry=3 e bantime progressivo — nunca desativar fora de exercícios controlados.
- Desativar permanentemente o acesso anónimo e a escrita no vsftpd, restringindo a autenticação a utilizadores nomeados.
- Implementar política de passwords fortes (mínimo 16 caracteres) para todas as contas com acesso remoto.
- Expandir o mecanismo de canário (Canary Watcher) para monitorizar múltiplos diretórios sensíveis, não apenas um ficheiro isolado.

12. Lições Aprendidas

A deteção funcionou corretamente e em tempo quase real, tanto pelos logs de autenticação como pelo mecanismo de canário próprio, o que confirma o valor de ter camadas de deteção redundantes. Fica também claro que medidas reativas como o Fail2ban não substituem a eliminação da causa raiz - a prioridade deve ser sempre reduzir a superfície de ataque (desativar autenticação por password, fechar acesso anónimo) em vez de depender apenas de deteção e resposta.